

Manufacturing Supply Chain Compromise

Cyber Tabletop Exercise — Facilitator-Ready PDF

Scenario source: STIX bundle *05_manufacturing_supplychain.json* | Generated: 22 June 2026

Exercise purpose

This tabletop exercise simulates a malicious software update distributed by a trusted industrial software supplier, resulting in operational disruption across manufacturing execution systems at Global Precision Manufacturing. The exercise is designed to test decision-making, escalation, operational resilience, technical containment, vendor assurance, and recovery governance.

Exercise profile	Recommended setting
Audience	Executive crisis leadership, plant leadership, operations, OT/IT security, SOC, legal, communications, procurement/vendor risk, business continuity
Duration	90 minutes, with optional 30-minute after-action debrief
Format	Facilitated discussion with four timed injects and decision points
Primary impact	Production instability, suspected vendor update compromise, outbound encrypted communications, controlled shutdown and recovery
Threat theme	Nation-state supply-chain intrusion using a trusted supplier update channel

1. Introduction

Global Precision Manufacturing operates production environments supported by a central Manufacturing Execution System. A trusted supplier, Industrial Software Supplier, releases a routine update that is later suspected to contain FactoryBackdoor, a backdoor distributed through the vendor software update mechanism. The situation evolves from operational instability to a confirmed cyber incident requiring containment, controlled shutdown, supplier coordination, executive decisions, and safe restoration.

This exercise is fictional and intended to promote structured discussion. It is not a technical test of any specific vendor or product.

2. Scope and Objectives

Scope

- Assess the organization's ability to detect, triage, escalate, and manage a suspected supply-chain cyber incident affecting production environments.
- Exercise coordination between plant operations, IT, OT engineering, SOC/incident response, vendor management, legal, communications, and executive crisis leadership.
- Validate decision-making for suspending vendor updates, isolating affected systems, invoking business continuity, and restoring known-good baselines.
- Clarify how operational safety, production commitments, customer obligations, regulatory reporting, and supplier accountability are balanced during the incident.

Objectives

- Confirm who has authority to pause software deployment, isolate MES-connected systems, and order a controlled production shutdown.
- Test escalation thresholds from IT incident to cyber incident to crisis management activation.
- Evaluate the completeness of vendor assurance, software integrity validation, and reconnection protocols.
- Assess continuity options for critical manufacturing workflows when the MES is degraded or unavailable.
- Identify lessons learned for supplier risk management, update governance, segmentation, logging, and backup/restore readiness.

3. Rules of Engagement

- Real incidents take priority. Participants should identify any live operational conflicts to the facilitator.
- There are no perfect answers. The exercise is intended to reveal assumptions, gaps, and improvement opportunities.
- Participants should respond based on their actual roles, authorities, procedures, and escalation paths.
- Do not fight the scenario. Request clarification where needed, but assume the provided inject information is accurate.
- Avoid deep technical troubleshooting unless it informs a decision, escalation, containment action, or business impact assessment.

4. Participants and Expected Roles

Role	Exercise focus
Executive / Crisis Leadership	Business impact, risk acceptance, shutdown decisions, external commitments, public and customer posture
Plant Operations / OT Leadership	Safety, production continuity, manual workarounds, operational constraints, restart sequencing

Role	Exercise focus
SOC / Incident Response	Detection, containment, evidence preservation, malware triage, reconnection criteria, monitoring
IT / MES Application Owner	Update deployment history, system dependencies, backup/restore, access control, vendor coordination
Legal / Compliance	Regulatory notification analysis, contractual obligations, evidence handling, privilege and documentation
Communications / Customer Relations	Internal messaging, employee guidance, customer and supplier communications
Procurement / Third-Party Risk	Supplier assurance, contract clauses, attestation, update governance, remediation commitments
Business Continuity / Resilience	Continuity plans, production prioritization, recovery time objectives, after-action tracking

5. Scenario Overview

STIX-derived element	Scenario interpretation
Target organization	Global Precision Manufacturing
Supplier	Industrial Software Supplier
Critical infrastructure / system	Manufacturing Execution System — central production management system controlling manufacturing workflows
Threat actor	Supply Chain Intrusion Group — assessed as a nation-state supply-chain intrusion group
Malware	FactoryBackdoor — backdoor delivered through a compromised vendor software update
Incident	Compromised Vendor Update Incident — manufacturing disruption caused by a malicious supplier update
Known response actions	Suspend vendor updates; restore trusted system baselines from known-good configurations and validated backups

Assumed exercise context

- The update was approved through the standard maintenance process and deployed first to a subset of production-adjacent systems before wider rollout.
- The MES has dependencies with plant-floor controllers, scheduling, quality data capture, and production reporting.
- The organization has segmented IT/OT architecture, but some MES services require controlled outbound connectivity for vendor support and telemetry.
- No confirmed data exfiltration is known at exercise start; the primary concern is integrity, operational disruption, and potential persistence.

6. Exercise Timeline and Injects

Inject 1 — Software Update Deployment

Exercise time	Day 1, 08:30 local plant time
STIX note	Operations teams deploy a newly released software update from a trusted industrial software supplier across production systems.
Situation	Operations teams deploy a newly released update from the trusted industrial software supplier to MES-connected production systems. Initial checks show the update installed successfully, and no vendor advisory indicates cyber risk.
Key decision	Should deployment continue, pause, or move to enhanced monitoring while additional integrity checks are performed?

Discussion questions

- Who approves update deployment into production and who can pause it?
- Was the update tested in a staging environment representative of production?
- What evidence confirms the software package source, integrity, signing status, and deployment scope?
- Which teams need to be notified if the deployment is paused?

Expected actions / good-practice indicators

- Confirm deployed versions, affected hosts, deployment timestamps, and rollback options.
- Validate hashes, signatures, release notes, change tickets, and vendor communication channels.
- Increase monitoring for affected MES hosts and restrict further deployment until checks complete.
- Document decision ownership and establish a shared incident log.

Facilitator note: Watch for unclear ownership between IT change management, OT engineering, and plant leadership. Prompt participants to distinguish normal change rollback from cyber containment.

Inject 2 — Production Instability

Exercise time	Day 1, 11:15 local plant time
STIX note	Multiple production lines begin experiencing unexpected stoppages and abnormal machine behavior following the software update.
Situation	Multiple production lines experience unexpected stoppages, abnormal machine behavior, and inconsistent job scheduling after the update. Operators report recurring MES session errors and intermittent delays in production order release.
Key decision	Does the organization treat this as an operational incident, a suspected cyber incident, or both?

Discussion questions

- What immediate steps protect personnel safety, product quality, and equipment integrity?
- What severity should be assigned and who is escalated?
- Are manual production workarounds available, approved, and safe?
- What production commitments, customer deliveries, or regulatory obligations may be affected?

Expected actions / good-practice indicators

- Engage plant operations, OT engineering, MES owner, SOC, and business continuity leads.
- Pause further update deployment and preserve logs, endpoint telemetry, and deployment artifacts.
- Define production lines that can safely continue, must be slowed, or must stop.
- Prepare internal communications for plant leadership and affected teams.

Facilitator note: Ensure participants do not let the SOC make operational safety decisions alone. Safety and production continuity should be led by operations with cyber input.

Inject 3 — Malicious Communications Detected

Exercise time	Day 1, 14:30 local plant time
STIX note	Security monitoring identifies outbound encrypted communications from manufacturing systems to previously unseen external infrastructure.
Situation	Security monitoring identifies outbound encrypted communications from MES-related systems to previously unseen external infrastructure. The traffic began shortly after update deployment. The vendor states it is investigating but has not confirmed compromise.
Key decision	Should affected systems be isolated, vendor connectivity blocked, and the crisis cell activated?

Discussion questions

- What containment action can be taken without creating unsafe plant conditions?
- What evidence is needed before declaring a confirmed cyber incident?
- Who contacts the supplier, and what specific information is requested?
- Do communications or legal teams need to prepare customer, regulator, or insurer notifications?

Expected actions / good-practice indicators

- Block suspicious external destinations and disable nonessential vendor remote connectivity.
- Isolate affected MES hosts or network segments using a controlled OT-safe containment plan.
- Start malware triage for FactoryBackdoor indicators and collect volatile/log evidence.
- Activate incident command or crisis management if thresholds are met.
- Request supplier attestations: affected versions, compromise scope, IOCs, remediation package, and safe rollback guidance.

Facilitator note: Probe whether teams know the reconnection criteria. Ask participants to define what 'safe to reconnect' means in measurable terms.

Inject 4 — Controlled Production Shutdown

Exercise time	Day 1, 17:00 local plant time
STIX note	Plant leadership orders a controlled shutdown of production systems while incident responders investigate the suspected supply chain compromise.
Situation	Plant leadership orders a controlled shutdown of impacted production systems while incident responders investigate the suspected supply-chain compromise. Customer orders and supplier schedules are at risk, and executives request an impact estimate and recovery path.
Key decision	How does the organization balance shutdown, restoration, supplier engagement, and business commitments?

Discussion questions

- Who owns the shutdown decision and restart approval?
- What systems must be rebuilt from known-good baselines before restart?
- How are customers, suppliers, employees, and leadership kept informed?
- What regulatory, contractual, or safety reporting obligations are triggered?
- What evidence must be retained for post-incident review, insurance, legal, or supplier claims?

Expected actions / good-practice indicators

- Execute controlled shutdown and maintain a single source of truth for impact and recovery status.
- Restore affected systems from known-good baselines and validated backups.
- Suspend vendor updates enterprise-wide pending integrity verification.
- Define restart sequence, validation testing, enhanced monitoring, and exception approvals.
- Prepare after-action report, lessons learned, and supplier remediation requirements.

Facilitator note: Encourage discussion of business trade-offs: lost production, safety risk, product quality, contractual penalties, and confidence required to restart.

7. Technical and Business Impact Prompts

Impact area	Prompts for participants
Safety and quality	Could abnormal MES behavior create unsafe plant states, defective output, or incomplete quality records? Who has authority to stop affected lines?
Production continuity	Which orders or lines are highest priority? What manual or degraded-mode processes exist, and how long can they operate?
Cyber containment	Can outbound connections be blocked without impairing safe shutdown? Are affected systems segmented from other plants or corporate IT?
Supplier dependency	What evidence is required from the supplier before updates resume? Are contract clauses sufficient for incident disclosure and remediation?
Recovery	Are known-good baselines, gold images, and backups current, validated, and isolated from the compromised update path?
Communications	What should employees, customers, logistics partners, and leadership be told at each stage? Who approves external statements?
Regulatory / legal	Are there safety, critical infrastructure, privacy, contractual, or sector reporting obligations? What deadlines and evidence standards apply?

8. Facilitator Guide

Recommended exercise flow

Segment	Duration	Facilitator intent
Opening, objectives, roles	10 min	Align on scope, rules, and expected participation
Inject 1	15 min	Test change governance and deployment visibility
Inject 2	20 min	Test operational safety, escalation, and early containment
Inject 3	25 min	Test cyber incident declaration, vendor coordination, and technical containment
Inject 4	20 min	Test shutdown/recovery governance and external obligations
Debrief	15–30 min	Capture strengths, gaps, decisions, and action owners

Facilitator cues

- When participants jump to technical fixes, ask who is accountable for the decision and what business risk the action creates.
- When participants assume vendor statements are sufficient, ask what independent validation is required.
- When participants suggest reconnection, ask for objective criteria: clean builds, validated backups, IOCs checked, monitoring enabled, supplier assurance received, and business approval.
- When participants discuss communications, ask who owns messages to plant employees, customers, suppliers, regulators, and executives.

9. Debrief and Lessons Learned

Use the following questions to structure the after-action discussion.

- What worked well in escalation, command structure, and decision-making?
- Where were roles or authorities unclear?
- Were software update approvals, vendor assurance checks, and rollback procedures sufficient?

- Did teams have the right visibility into MES behavior, network communications, and vendor connectivity?
- Were production continuity options realistic and safe?
- What evidence would be needed for regulatory reporting, legal analysis, or supplier remediation?
- Which improvements should be prioritized within 30, 60, and 90 days?

Suggested observations rating

Observation statement	Confidence rating (1–5)	Action owner / notes
We can rapidly identify all systems receiving a vendor software update.		
We can pause or roll back an update without unclear ownership.		
We can detect abnormal outbound communications from production systems.		
We can contain MES-related systems without causing unsafe plant conditions.		
We have tested known-good baselines and validated backups for MES recovery.		
We know what information to request from a compromised supplier.		
We understand notification obligations and approval paths.		

10. MITRE ATT&CK; Mapping

The STIX bundle explicitly identifies T1195.002. Additional mappings below are exercise-derived and should be validated against internal telemetry and final incident findings.

Tactic	Technique / sub-technique	Scenario reflection	Exercise validation prompt
Initial Access	T1195.002 — Supply Chain Compromise: Compromise Software Supply Chain	FactoryBackdoor is delivered through a compromised vendor software update.	Can the organization validate package origin, signatures, hashes, update channels, and supplier attestations?
Execution	T1204.002 — User Execution: Malicious File	A trusted update package is executed through normal deployment processes; user action may be indirect via change execution.	Are deployment tools monitored for unexpected child processes or unsigned binaries after update execution?
Persistence	T1543.003 — Create or Modify System Process: Windows Service	A backdoor in a production software component may establish service-level persistence. This is a plausible exercise assumption, not explicitly stated in STIX.	Do EDR/allowlisting controls detect new or modified services on MES hosts?
Defense Evasion	T1553.002 — Subvert Trust Controls: Code Signing	Supply-chain attacks often abuse trust in signed or approved software distribution. The exercise tests verification beyond supplier trust.	Are code-signing and certificate anomalies reviewed before broad deployment?
Command and Control	T1573 — Encrypted Channel	Security monitoring identifies outbound encrypted communications to previously unseen infrastructure.	Can monitoring distinguish approved vendor telemetry from suspicious encrypted egress?
Command and Control	T1071.001 — Application Layer Protocol: Web Protocols	Outbound communications may blend with normal web-based vendor support or update traffic. This is a plausible exercise assumption.	Are destinations allowlisted and monitored for new domains, IPs, and unusual beacon patterns?
Exfiltration	T1041 — Exfiltration Over C2 Channel	No exfiltration is confirmed, but encrypted C2 creates a risk that should be evaluated during investigation.	What evidence would confirm or rule out data loss from MES or production reporting systems?
Impact	T1489 — Service Stop	Production instability and shutdown affect availability of manufacturing workflows.	Can teams separate malicious service interruption from controlled safety shutdown?
Impact	T1565.001 — Data Manipulation: Stored Data Manipulation	Abnormal machine behavior raises integrity concerns for schedules, recipes, quality records, or production orders.	What validation confirms production data and quality records remain trustworthy?

11. Improvement Backlog

Priority	Recommended action	Owner	Target timeframe
High	Create a vendor software update assurance checklist covering source validation, hash/signature verification, staging tests, rollback, and supplier notification channels.	IT / OT / Vendor Risk	30 days
High	Define OT-safe containment and reconnection criteria for MES and production networks.	SOC / OT Engineering	30 days
High	Inventory MES dependencies and map which production lines, quality systems, and reporting functions are affected by MES outage.	Plant Ops / MES Owner	45 days
Medium	Review supplier contracts for incident notification timelines, IOCs, remediation support, forensic cooperation, and indemnification.	Legal / Procurement	60 days
Medium	Test restoration from known-good MES baselines and validated backups in a controlled environment.	IT / OT Recovery	60–90 days

Priority	Recommended action	Owner	Target timeframe
Medium	Develop customer, employee, and regulator communication templates for production-impacting cyber incidents.	Comms / Legal / Crisis Mgmt	60 days

Appendix A — Source Inputs

- STIX bundle: 05_manufacturing_supplychain.json, containing 18 objects including identities, infrastructure, threat actor, malware, attack pattern, incident notes, courses of action, report, and relationships.
- MITRE ATT&CK technique validation used official MITRE ATT&CK references for T1195.002 and related techniques.

End of exercise package.